UNIVERSIDAD DE OCCIDENTE
SEDE CENTRAL
FACULTAD DE INGENIERÍA
INGENIERIA EN SISTEMAS



Elaborado por:

Oscar Daniel Flores Chaclán - 2301002001
Marlon José Ovalle Farfán - 2201002008
Diego Armando Paxtor Tebalán - 2301002036

QUETZALTENANGO, NOVIEMBRE 2026

1. Resumen ejecutivo

El caso académico Operación Trazabilidad describe una interrupción del CRM de RedNova Guatemala, S. A. el 14 de octubre de 2026, precedida por señales de acceso remoto sin MFA, elevación de privilegios, lectura masiva, transferencia de datos, modificaciones de órdenes, despliegue de integración y una alerta crítica. La revisión documental permite identificar riesgos relevantes, ordenar pruebas y proponer acciones; sin embargo, las fuentes originales de E-01 a E-10 no constan recibidas ni autenticadas.

Por esa razón, este informe distingue entre hechos descritos en el enunciado, señales reportadas, resultados de laboratorio con datos sintéticos, hipótesis y recomendaciones. No se confirma causa raíz, autoría, exfiltración, fraude, pérdida económica ni incumplimiento contractual o legal. H-04 y H-05 permanecen no concluyentes.

Elemento	Resultado integrado
Alcance	CRM, SQL Server, ERP, aplicación móvil, identidad/VPN, nube y respaldos, SIEM, API/chatbot IA, ventas, facturación, cambios y continuidad.
Riesgos	Matriz R-01 a R-14; Top 5: R-03, R-08, R-07, R-13 y R-05, todos con 20/25.
Pruebas	Programa T-01 a T-15 diseñado; los papeles de trabajo indican DISEÑADA · NO EJECUTADA.
Evidencia	Inventario E-01 a E-10 y PT-01 a PT-10 preparados. Originales, fechas de adquisición, custodios y hashes pendientes.
SQL	12 tablas, 83 campos documentados y 12 consultas SELECT reportadas como ejecutadas en SQL Server 2022 sobre datos sintéticos.
Hallazgos	Cinco borradores H-01 a H-05; H-01 a H-03 son observaciones sustentadas en el expediente, no equivalen a incumplimiento formal probado. H-04/H-05 no concluyentes.
Acciones	12 acciones propuestas en horizontes de 0–24 h a 30–90 días. Presupuesto académico máximo Q350,000; no es gasto ejecutado ni cotización.

Conclusión ejecutiva: priorizar preservación de fuentes, revisión de accesos privilegiados/MFA, análisis de cambios y alertas, restauración aislada y conciliación de órdenes. Las decisiones deben basarse en evidencia original y aprobación de los responsables.

2. Objetivo, alcance y metodología

2.1 Objetivo

Evaluar, desde un enfoque académico de auditoría de sistemas, los riesgos y controles relacionados con la seguridad, integridad, disponibilidad y trazabilidad de los sistemas que intervienen en el proceso comercial de RedNova, y reconstruir de forma preliminar las señales del incidente descrito.

2.2 Alcance

El Plan de Auditoría establece como período de referencia del 14 de septiembre al 14 de octubre de 2026. El alcance documental incluye CRM, SQL Server, ERP, aplicación móvil, identidad/VPN, nube y respaldos, SIEM, API, chatbot IA, ventas, facturación, gestión de cambios y continuidad.

Se excluyen pruebas en producción, uso de datos reales, explotación de vulnerabilidades, acciones intrusivas y acceso a credenciales o información personal real. La arquitectura y el inventario son modelos lógicos del caso, no una CMDB ni una topología autenticada.

2.3 Metodología y criterio de evidencia

- Revisión del enunciado, guía de entregables, plan, matrices, papeles de trabajo, hallazgos, plan de acción, documentos de Paso 9 y material técnico SQL.
- Separación entre hechos del caso, señales reportadas, resultados sintéticos, hipótesis, criterios de control y recomendaciones.
- Evaluación de riesgos con probabilidad e impacto de 1 a 5; el puntaje expresa juicio de auditoría del escenario, no frecuencia estadística.
- Trazabilidad prevista: RIESGO → CONTROL → PRUEBA → EVIDENCIA → HALLAZGO → ACCIÓN → VERIFICACIÓN → RIESGO RESIDUAL.
- No se reduce el riesgo residual mientras no existan pruebas suficientes, evidencia identificable y aprobación correspondiente.

Las referencias NIST se emplean como guías técnicas. Su mención no demuestra que sean obligaciones legales o contractuales aplicables a la entidad ficticia. Los criterios internos y contractuales deben ser aportados y aprobados antes de declarar incumplimientos.

3. Contexto, activos y arquitectura lógica

El escenario describe una organización con operación comercial apoyada en CRM, base SQL Server, ERP, aplicación móvil, servicios de identidad y VPN, nube/respaldos, SIEM, API e integración y chatbot con IA. El flujo lógico conecta la gestión de clientes y órdenes con la persistencia en SQL Server y los procesos financieros/operativos del ERP.

Activo / proceso	Función descrita	Riesgos vinculados	Límite de revisión
CRM comercial	Clientes, contratos, órdenes y ventas.	R-05; R-13	Interfaces, hospedaje, cambios y conciliación efectivos no autenticados.
SQL Server	Datos comerciales, operativos y de facturación.	R-07; R-09; R-13	Permisos, topología y logs productivos no verificados.
ERP	Facturación, cobros, inventarios y finanzas.	R-13	Conciliación CRM–ERP y reglas comerciales por validar.
Identidad / VPN	Autenticación y acceso remoto.	R-01; R-02; R-03	Configuración real y cobertura MFA pendientes.
Nube / respaldos	Hospedaje y recuperación.	R-06; R-08	Contrato, arquitectura y pruebas de restauración incompletos.
SIEM / respuesta	Monitoreo y alertamiento.	R-11	Eventos originales y tickets no aportados.
API / chatbot IA	Integraciones y atención automatizada.	R-04; R-14	Permisos, trazas, versión y pruebas no disponibles.

El diagrama lógico y el flujo comercial incluidos en el expediente son modelos académicos. El diagrama entidad-relación del laboratorio se deriva únicamente de las claves foráneas explícitas declaradas en RedNova.sql; no representa todas las relaciones funcionales posibles ni una base productiva.

4. Evaluación de riesgos y priorización

La matriz contiene R-01 a R-15. La evaluación inherente se mantiene como referencia de priorización; los controles no se consideran eficaces hasta que su diseño y operación se prueben. Los riesgos residuales permanecen al nivel inherente.

Orden	Riesgo	P×I	Tema	Justificación	Precaución
1.0	R-03	4×5 = 20	Acceso privilegiado sin MFA	Afecta una barrera transversal de entrada a sistemas críticos; la cronología reporta una sesión externa sin MFA.	No atribuir la cuenta al ataque ni dar por probada la cobertura completa de MFA.
2.0	R-08	4×5 = 20	Restauración de respaldos	La continuidad del CRM es crítica y el expediente señala restauraciones no probadas recientemente.	No afirmar que los respaldos fallaron ni estimar RTO/RPO sin BIA y pruebas.
3.0	R-07	4×5 = 20	Clasificación de datos personales	La información de clientes requiere protección transversal; el caso reporta falta de clasificación formal.	La lectura de 31,840 filas y el tráfico no prueban exposición o fuga.
4.0	R-13	4×5 = 20	Integridad de órdenes	Los 216 cambios reportados y la conciliación solicitada afectan el núcleo comercial y financiero.	No afirmar fraude, cambios ilegítimos o pérdidas sin historial y conciliación.
5.0	R-05	4×5 = 20	Gestión de cambios	El despliegue no tiene aprobación final documentada y puede afectar varias integraciones.	La secuencia temporal no demuestra que causó la indisponibilidad.

El orden del Top 5 es un desempate de juicio profesional entre riesgos con igual puntaje, no una clasificación de certeza forense. R-03 prioriza el acceso privilegiado/MFA; R-08 la capacidad de restauración; R-07 la clasificación y protección de datos; R-13 la integridad y conciliación de órdenes; R-05 la gestión de cambios.

La matriz completa R-01 a R-15 se conserva en el archivo Matriz_Riesgos.xlsx, que forma parte del expediente de trabajo. Este informe no reemplaza la matriz detallada.

5. Programa de auditoría y pruebas

El programa define T-01 a T-15 con control esperado, procedimiento, población o muestra propuesta, evidencia esperada, criterio, SQL relacionado y papel de trabajo. El programa es diseño de auditoría: no hay pruebas T-XX ejecutadas acreditadas en el expediente.

Estado	Interpretación
T-01 a T-15	DISEÑADAS · NO EJECUTADAS según programa y papeles de trabajo.
SQL-01 a SQL-12	Consultas del laboratorio ejecutadas sobre datos sintéticos; no son pruebas T-XX ni evidencia productiva.

Criterios	Algunos criterios internos/contractuales simulados requieren aprobación o documentación.
Cierre de prueba	Requiere población/muestra, procedimiento reproducible, criterio aplicable, evidencia identificable, resultado y conclusión.

Por tanto, no se presentan tasas de cumplimiento ni resultados de efectividad de controles. Las consultas SQL ilustran análisis posibles y ayudan a preparar pruebas posteriores.

6. Papeles de trabajo, inventario y cadena de custodia

Se prepararon diez papeles de trabajo PT-01 a PT-10 y un inventario E-01 a E-10. Los documentos se actualizaron para reflejar los límites conocidos y las referencias a resultados SQL sintéticos. No constan recibidos los archivos fuente originales independientes que permitan completar la adquisición y autenticación.

Referencia	Área	Señal / condición del expediente	Fuente original necesaria
E-01 / PT-01	Usuarios y privilegios	Cuentas activas sin recertificación reciente reportada.	Export IAM/RR. HH., titulares, roles y recertificaciones.
E-02 / PT-02	VPN / identidad	Sesión externa sin MFA reportada a las 02:17.	Logs VPN/IdP, ID sesión, dispositivo, autorización y titularidad.
E-03 / PT-03	SQL	Lectura reportada de 31,840 filas a las 02:31.	Auditoría SQL original, consulta, identidad, columnas y correlación.
E-04 / PT-04	Tráfico cloud	Transferencia aproximada de 1.6 GB a destino no clasificado.	Logs red/cloud, destino, contenido, proceso y autorización.
E-05 / PT-05	CRM / órdenes	216 modificaciones reportadas a las 02:42.	Antes/después, actores, bitácoras CRM/SQL y conciliación ERP.
E-06 / PT-06	Cambios	Aprobación final del despliegue no documentada.	Ticket, aprobación, QA, CI/CD, commits y rollback.
E-07 / PT-07	SIEM	Alerta crítica a las 03:18 sin cierre documentado.	Evento SIEM, ticket, acuse, escalamiento y respuesta.
E-08 / PT-08	Respaldos	Respaldos programados; restauración reciente no demostrada.	BIA, RTO/RPO, logs, actas y pruebas de integridad.
E-09 / PT-09	Proveedor	SLA 99.9%, exclusiones y cobertura SOC 2 parcial reportadas.	Contrato íntegro, anexos, SOC 2 completo y subprocesadores.
E-10 / PT-10	Chatbot IA	Valor anómalo 0.08 sin escala documentada.	Modelo/versión, umbral, logs, prompts, permisos y revisión humana.

La cadena de custodia permanece sin eventos porque no se documentaron recepciones, adquisiciones o transferencias reales de archivos originales. Fechas, custodios, ubicación y SHA-256 deben completarse únicamente al recibir y verificar cada archivo. No deben inventarse hashes ni firmas.

7. Análisis de base de datos y resultados SQL

El archivo RedNova.sql define 12 tablas. El diccionario de datos documenta 83 campos. Las relaciones declaradas por claves foráneas incluyen Privilegios.UsuarioId, Sesiones.UsuarioId, EventosPrivilegios.UsuarioId/SesionId, BitacoraConsultas.UsuarioId/SesionId, Transferencias.SesionId e HistorialOrdenes.OrdenId/UsuarioId.

El informe de verificación identifica SQL Server 2022 Developer Edition, versión 16.0.4305.5, en un contenedor local denominado sqlserver2022. Se reportan 12 consultas SELECT ejecutadas en el laboratorio. Evidencias_SQLServer.pdf corresponde a una transcripción del verificador .NET, no a capturas de SSMS.

Consulta	Uso descrito en el expediente	Limitación principal
SQL-01/02	Usuarios, privilegios y actividad.	Semilla sintética; no exportación IAM real.
SQL-03/11	Sesión sin MFA y actividad en horario inusual.	No atribuye una sesión productiva ni un actor.
SQL-04	Lectura agregada de 31,840 filas.	Identidad/sesión no autenticadas; no prueba exfiltración.
SQL-05/10	Modificaciones de órdenes y códigos duplicados.	Datos de laboratorio; no prueba fraude ni cambios reales.
SQL-06	Ticket/aprobación final ausente en la semilla.	NULL no prueba inexistencia de aprobación verbal o externa.
SQL-07	Alerta crítica sin cierre en laboratorio.	No demuestra que una alerta real fuera ignorada.
SQL-08/12	Respaldos e intervalos del laboratorio.	No establece RTO/RPO ni integridad de respaldos reales.
SQL-09	Transferencia aproximada de 1.6 GB.	Destino/contenido simulados o no autenticados.

Los resultados SQL son útiles para demostrar consultas y estructura del laboratorio, pero no sustituyen logs originales, capturas requeridas por la guía ni evidencia de ejecución de las pruebas T-XX.

8. Reconstrucción preliminar del incidente y continuidad

Hora (UTC−6)	Evento reportado	Precaución
02:17	Sesión externa sin MFA reportada (E-02).	No se autentica titularidad ni autorización.
02:26	Elevación de privilegios reportada.	No se prueba que corresponda a la misma sesión/actor.
02:31	Lectura de 31,840 filas reportada (E-03).	No se identifican campos ni origen autenticado.
02:35	Transferencia aproximada de 1.6 GB (E-04).	Destino y contenido no identificados.
02:42	216 órdenes modificadas (E-05).	Legitimidad y cambios antes/después pendientes.
03:02	Despliegue de integración (E-06).	Aprobación final no documentada; no prueba causalidad.
03:18	Alerta crítica (E-07).	No consta cierre; no prueba ausencia de respuesta.
03:42	CRM reportado indisponible.	No se autentica causa técnica.
04:05	Solicitud de recuperación.	No acredita inicio/fin de restauración.
08:57	Consultas disponibles en modo solo lectura.	Intervalo desde caída: 5 h 15 min.
09:37	Escrituras disponibles.	Intervalo desde caída: 5 h 55 min.
11:15	Finanzas solicita conciliación.	No consta conciliación concluida.

Los intervalos de 5 h 15 min hasta consultas y 5 h 55 min hasta escritura son cálculos descriptivos del escenario; no son RTO, RPO ni prueba de restauración íntegra. Para evaluar continuidad se requieren BIA, objetivos aprobados, punto de recuperación, logs y pruebas controladas.

Hipótesis de trabajo: (1) abuso de credenciales/acceso privilegiado con impacto en sistemas comerciales; (2) evento de disponibilidad relacionado con cambios o actividad maliciosa. Ambas requieren correlación de logs y evidencia original; ninguna se presenta como causa raíz confirmada.

9. Hallazgos preliminares

Los cinco hallazgos se mantienen vinculados a riesgos, pruebas, papeles de trabajo y evidencias. Los puntajes son inherentes y preliminares; no equivalen a riesgo residual ni a incumplimiento formal cuando falta criterio interno/contractual.

Código	Tema	Trazabilidad	P×I	Estado y límite
H-01	Acceso remoto sin MFA	R-03 / T-03 / PT-02 / E-02	4×5=20	Observación sustentada; criterio formal y atribución pendientes.
H-02	Despliegue sin aprobación final documentada	R-05 / T-05 / PT-06 / E-06	4×5=20	Observación sustentada; no se demuestra cambio no autorizado.
H-03	Alerta crítica sin cierre documentado	R-11 / T-11 / PT-07 / E-07	4×4=16	Observación sustentada; no se demuestra que fuera ignorada.
H-04	Restauración sin prueba reciente aportada	R-08 / T-08 / PT-08 / E-08	4×5=20	No concluyente; faltan política, BIA, RTO/RPO y evidencia completa.
H-05	216 órdenes pendientes de conciliación	R-13 / T-13 / PT-05 / E-05	4×5=20	No concluyente; no se ha probado modificación indebida.

9.1 Interpretación por hallazgo

- H-01: el expediente reporta una sesión externa sin MFA a las 02:17. Deben revisarse cuenta, privilegio, excepción, VPN/IdP y correlación con la elevación posterior. No atribuir el ataque a ext_ops_04.
- H-02: el despliegue de las 03:02 carece de aprobación final documentada en el material aportado. La aprobación verbal alegada debe contrastarse con el procedimiento vigente. Los eventos anteriores impiden atribuirle el inicio del incidente.
- H-03: la alerta crítica de las 03:18 no tiene cierre documentado en el expediente. Se deben buscar tickets, acuses, contención y escalamiento; no afirmar que Seguridad no actuó.
- H-04: la restauración reciente no está demostrada. Sin BIA, periodicidad aprobada y RTO/RPO no se declara incumplimiento.
- H-05: las 216 modificaciones deben conciliarse con ERP y facturación usando registros antes/después, actores y autorizaciones. El número no demuestra fraude ni pérdida económica.

La revisión cruzada y la hoja de validación de hallazgos no cuentan con firma, fecha y resultado en el expediente disponible. Esta limitación se mantiene declarada y no se presume aprobación.

10. Terceros, privacidad y uso de IA

10.1 Riesgo de terceros (TPRM)

El proveedor cloud no está identificado por nombre en el expediente. Se reporta un SLA de 99.9% con exclusiones sujetas a interpretación, subcontratistas no incluidos inicialmente en la evaluación y cobertura parcial del informe SOC 2. No se recibió el contrato íntegro ni el SOC 2 completo; por ello la evaluación se mantiene no concluyente.

10.2 Privacidad

La matriz de privacidad identifica datos de clientes, contratos, órdenes, ventas, facturación y operaciones en CRM, SQL Server y ERP. En varios procesos no se especifican quién accede, ubicación/transferencias ni medidas concretas de protección. La lectura de 31,840 filas y la transferencia reportada no demuestran por sí solas exposición de datos personales.

10.3 Chatbot IA

El expediente reporta un valor 0.08 asociado a una sesión anómala, pero no documenta escala, umbral, modelo, versión ni significado. No puede calificarse como alto o bajo. Las pruebas de exactitud, protección de información, permisos y supervisión humana siguen pendientes; T-14 está diseñada, no ejecutada.

Área	Estado actual	Información necesaria
Contrato / SLA	No concluyente.	Contrato, anexos, exclusiones, mediciones y responsabilidades.
SOC 2 / subprocesadores	Cobertura parcial reportada.	Informe íntegro, periodo, alcance y lista de subprocesadores.
Privacidad	Información insuficiente.	Roles de acceso, ubicación, transferencias, controles y retención.
Chatbot IA	Valor 0.08 sin escala.	Modelo/versión, escala, umbrales, logs, permisos, pruebas y supervisión.

11. Plan de acción, presupuesto y seguimiento

El plan contempla 12 acciones A-01 a A-12 con horizontes de 0–24 horas, 24–72 horas, 7–30 días y 30–90 días. Son recomendaciones, no actividades ejecutadas. La asignación económica es una propuesta académica dentro del límite Q350,000; no constituye cotización, contrato ni gasto realizado.

Acción	Hallazgo	Riesgo	Horizonte	Acción propuesta	Presupuesto Q	Verificador
A-01	H-01–H-05	R-03; R-05; R-11; R-08; R-13	0–24 h	Preservar logs VPN/IAM, SIEM, CRM, CI/CD y respaldos antes de cambios; generar copias de trabajo, huellas y custodia.	15000	Auditoría / Diego
A-02	H-01	R-03	0–24 h	Administración revoca sesiones sospechosas, revisa cuenta externa y aplica MFA/restricción temporal a accesos privilegiados.	10000	Auditoría / Marlon
A-03	H-04 (no concluyente)	R-08	24–72 h	Comprobar respaldo limpio e integridad; ejecutar restauración de verificación en entorno aislado y documentar punto recuperable.	25000	Auditoría / Oscar
A-04	H-05 (no concluyente)	R-13	24–72 h	Conciliar las 216 modificaciones	15000	Auditoría / Oscar

				reportadas con historial, autorizaciones, ERP y facturación; clasificar diferencias.		
A-05	H-03	R-11	24–72 h	Reconstruir recepción, asignación, respuesta y cierre de alerta crítica; corregir vacíos del ticket sin inferir falta de actuación.	15000	Auditoría / Diego
A-06	H-01	R-03	7–30 días	Inventariar cuentas privilegiadas; desplegar MFA resistente a phishing y control de privilegios, con excepciones temporales aprobadas.	75000	Auditoría / Marlon
A-07	H-02	R-05	7–30 días	Bloquear despliegues sin ticket, aprobación previa, prueba y rollback; documentar vía de emergencia y revisión posterior.	35000	Auditoría / Marlon
A-08	H-03	R-11	7–30 días	Integrar SIEM con tickets, responsables, escalamiento y retención protegida; definir plazos internos de atención.	40000	Auditoría / Diego
A-09	H-04 (no concluyente)	R-08	7–30 días	Ampliar pruebas de restauración CRM/SQL en aislamiento, corregir fallos demostrados y conservar resultados.	40000	Auditoría / Oscar
A-10	H-05 (no concluyente)	R-13	30–90 días	Automatizar conciliación diaria CRM–ERP y trazabilidad antes/después solo si A-04 confirma brecha o volumen recurrente.	35000	Auditoría / Marlon
A-11	H-04 (no concluyente)	R-08; R-10	30–90 días	Actualizar BIA de ventas/facturación; aprobar RTO/RPO CRM/ERP y plan de continuidad, y contrastarlos con ensayos.	25000	Auditoría / Oscar
A-12	H-01–H-05	R-03; R-05; R-11; R-08; R-13	30 y 90 días	Reauditar diseño y operación de controles, registrar excepciones y someter el riesgo residual a decisión del comité.	20000	Comité de Auditoría

11.1 Presupuesto y supuestos

Presupuesto máximo del caso: Q350,000. La hoja de presupuesto contiene supuestos explícitos de costos unitarios y paquetes; deben validarse con cotizaciones antes de cualquier contratación. La asignación propuesta por el

coordinador contempla componentes firmes y condicionados según el plan; los Q75,000 condicionados dependen de diagnóstico. No se debe presentar como gasto ejecutado ni aprobación del Comité.

11.2 KPI y reauditoría

El plan propone comprobaciones a 30 y 90 días, con evidencia de cierre, responsable operativo y verificador. Las metas son propuestas de gestión, no resultados obtenidos ni criterios contractuales ya aprobados. El riesgo residual se reevaluará únicamente tras evidencia suficiente y validación.

Los riesgos diferidos fuera del sobre presupuestario no se consideran aceptados; la aceptación formal corresponde al Comité o autoridad designada, no al auditor.

12. Organización del equipo y declaración de uso de IA

Integrante	Responsabilidad principal consignada	Uso de IA resumido en el registro
Marlon · Integrante 1	Coordinación, plan, riesgos, plan de acción y compilación.	Apoyo con ChatGPT para estructurar matriz/programa, conciliar referencias y organizar plan de acción/presupuesto.
Oscar · Integrante 2	Arquitectura, laboratorio SQL, análisis técnico/forense y Paso 10 según acuerdo del equipo.	Apoyo con Codex para revisar arquitectura, SQL, cronología, hallazgos y organizar exposición técnica.
Diego · Integrante 3	Papeles de trabajo, inventario/custodia, TPRM/privacidad/IA y revisión cruzada.	Consultas puntuales a ChatGPT para aclarar documentos, revisar pendientes y orientar organización de entregables; uso moderado, sin atribuirle pruebas ni generación técnica.

El registro de IA integra las declaraciones y documentos individuales disponibles. Para Diego no se dispone de fechas exactas ni prompts textuales completos; por ello se consigna únicamente el uso declarado de consultas puntuales. Los tres integrantes deben confirmar que la descripción refleja su uso real. La IA no autenticó evidencia, no ejecutó pruebas de auditoría ni reemplaza el juicio profesional.

12.1 Estado de revisión y validación

El control de calidad y compilación conserva criterios marcados En revisión en el expediente consultado. El presente informe se emite como versión final documental con esas limitaciones expresas; no se atribuye validación a criterios que carecen de comprobación.

Responsable	Validación pendiente
Marlon	Revisar coherencia del informe, riesgos, presupuesto, acciones y conclusiones.
Oscar	Confirmar arquitectura, diagrama ER, laboratorio SQL, trazabilidad técnica y hallazgos del Paso 10.
Diego	Confirmar PT-01 a PT-10, inventario E-01 a E-10, Paso 9, registro de IA y revisión cruzada.
Equipo	Aprobar versión final, completar firmas/fechas y verificar que anexos y referencias coincidan.

13. Conclusiones y decisiones requeridas

- El expediente permite priorizar riesgos y preparar pruebas, pero no autentica los eventos descritos ni determina causa raíz.
- No se confirma exfiltración por la transferencia de 1.6 GB, ni acceso ilícito por la lectura de 31,840 filas, ni fraude por las 216 modificaciones.
- El despliegue de las 03:02 ocurre después de las señales de 02:17–02:42 y no puede considerarse causa inicial sin evidencia adicional.
- La falta de cierre documentado de una alerta no prueba que no existiera respuesta; un campo NULL o un documento ausente no prueba que nunca existiera aprobación.
- Los intervalos de recuperación observados no son objetivos RTO/RPO. La restauración y la conciliación deben verificarse con fuentes originales.
- El análisis SQL se ejecutó sobre datos sintéticos; no es evidencia productiva ni acredita pruebas T-XX.
- Los hallazgos H-01 a H-03 son observaciones sustentadas en el expediente, con criterios formales aún por validar; H-04 y H-05 son no concluyentes.
- Las acciones y el presupuesto son propuestas académicas pendientes de aprobación, financiación y ejecución.

Decisiones solicitadas

- Autorizar preservación prioritaria de logs VPN/IdP, SQL, CRM, red/cloud, SIEM, CI/CD y respaldos, con cadena de custodia verificable.
- Solicitar evidencia original E-01 a E-10 y completar inventario, custodio, fechas, ubicación y hashes.
- Validar accesos privilegiados y cobertura MFA, incluidas excepciones de terceros.
- Ejecutar diagnóstico de restauración en ambiente aislado y aprobar BIA/RTO/RPO.
- Conciliar las 216 órdenes con ERP/facturación antes de concluir sobre integridad o impacto financiero.
- Completar debida diligencia del proveedor cloud y pruebas del chatbot IA en entorno autorizado.
- Realizar revisión cruzada, resolver observaciones del control de calidad y aprobar formalmente la versión final.

ANEXO TÉCNICO 1. MATRIZ CONSOLIDADA DE RIESGOS R-01 A R-15

La siguiente síntesis conserva los quince riesgos de la matriz fuente. Los riesgos son potenciales y no constituyen por sí mismos hallazgos. Los puntajes corresponden a evaluación inherente; el diseño y la operación de los controles no están comprobados y el riesgo residual se mantiene sin reducción.

ID	Activo / proceso	Riesgo potencial	P×I	Nivel	Control esperado
R-01	Ciclo de vida de identidades	Acceso no autorizado mediante cuentas de personas desvinculadas que permanezcan activas.	4×4=16	Crítico	Baja oportuna, conciliación RR. HH.–IAM y recertificación de cuentas.
R-02	Cuentas privilegiadas	Pérdida de atribución y uso indebido de privilegios por cuentas administrativas compartidas.	4×4=16	Crítico	Cuentas nominativas, gestor de privilegios y revisión de actividad individual.
R-03	Acceso remoto privilegiado / VPN	Ingreso privilegiado no suficientemente protegido si MFA no cubre accesos externos.	4×5=20	Crítico	MFA obligatorio para todo acceso privilegiado, revisión de excepciones y sesiones.
R-04	Aplicación móvil, API y CRM	Consulta o modificación de datos ajenos al perfil por autorización insuficiente entre canales.	3×5=15	Alto	Autorización por objeto y rol, denegación por defecto y pruebas negativas.
R-05	Cambios del servicio de integración	Despliegue no controlado que introduzca fallos o altere procesos por aprobación y pruebas no documentadas.	4×5=20	Crítico	Aprobación formal, pruebas previas, segregación y reversión documentada.
R-06	Proveedor cloud y subcontratistas	Controles de terceros insuficientes por subcontratistas fuera de evaluación y cobertura SOC 2 incompleta.	3×4=12	Alto	TPRM por servicio y subcontratista; revisión del alcance SOC 2 y contrato.
R-07	Datos personales de clientes	Tratamiento y exposición no controlados de datos personales sin clasificación formal verificable.	4×5=20	Crítico	Clasificación e inventario de datos, mínimo privilegio, cifrado y monitoreo de flujos.
R-08	Respaldos y recuperación CRM	Imposibilidad de recuperar íntegra y oportunamente información si los respaldos no se restauran y verifican.	4×5=20	Crítico	Pruebas periódicas de restauración, integridad, RTO/RPO derivados del BIA.
R-09	Bitácoras de auditoría	Pérdida de integridad o disponibilidad de logs si administradores pueden alterarlos o eliminarlos.	3×5=15	Alto	Segregación, envío inmutable de logs, retención y revisión de permisos.
R-10	BIA y continuidad del negocio	Recuperación desalineada con necesidades de negocio por BIA y planes desactualizados.	3×5=15	Alto	BIA vigente, RTO/RPO aprobados y simulacros con conciliación.
R-11	Monitoreo y respuesta SIEM	Detección o escalamiento tardío si alertas críticas no se investigan y cierran con evidencia.	4×4=16	Crítico	Procedimiento de triage, dueño, SLA interno de atención y cierre verificable.
R-12	Flujo de datos hacia destino externo	Transferencia no autorizada de datos por falta de clasificación y trazabilidad del tráfico saliente.	3×5=15	Alto	Inventario de destinos, clasificación de tráfico, autorización y correlación de logs.

R-13	Órdenes CRM y facturación ERP	Órdenes alteradas o no conciliadas que produzcan errores de facturación e integridad transaccional.	4×5=20	Crítico	Autorización de cambios, historial antes/después y conciliación CRM–ERP.
R-14	Chatbot con IA y API	Respuesta errónea o divulgación de datos por falta de evaluación de privacidad, exactitud y supervisión.	3×4=12	Alto	Evaluación IA, permisos, pruebas de exactitud, logging y revisión humana.
R-15	Comité de Riesgos y supervisión	Priorización y seguimiento deficientes si faltan indicadores consolidados de ciberseguridad y terceros.	3×4=12	Alto	KRIs/KPIs consolidados, revisión periódica y decisiones de riesgo documentadas.

ANEXO TÉCNICO 2. PROGRAMA DE PRUEBAS T-01 A T-15

Las quince pruebas se encuentran diseñadas, no ejecutadas. La tabla identifica riesgo asociado, control prioritario, papel de trabajo y estado. Los procedimientos, muestras propuestas, evidencia esperada y límites completos permanecen en el programa fuente.

Prueba	Riesgo	Control prioritario / esperado	PT	Estado
T-01	R-01	Baja y recertificación de cuentas	PT-01	DISEÑADA · NO EJECUTADA
T-02	R-02	Cuentas privilegiadas individuales	PT-01	DISEÑADA · NO EJECUTADA
T-03	R-03	MFA en todo acceso remoto privilegiado	PT-02	DISEÑADA · NO EJECUTADA
T-04	R-04	Autorización por objeto y rol en móvil/API/CRM	PT-01; PT-05	DISEÑADA · NO EJECUTADA
T-05	R-05	Aprobación, pruebas y reversión antes de despliegue	PT-06	DISEÑADA · NO EJECUTADA
T-06	R-06	Evaluación de subcontratistas y cobertura contractual	PT-09	DISEÑADA · NO EJECUTADA
T-07	R-07	Inventario y clasificación de datos personales	PT-03; PT-04	DISEÑADA · NO EJECUTADA
T-08	R-08	Restauración íntegra contra objetivos aprobados	PT-08	DISEÑADA · NO EJECUTADA
T-09	R-09	Integridad y retención de logs	PT-07	DISEÑADA · NO EJECUTADA
T-10	R-10	BIA vigente y objetivos consistentes	PT-08	DISEÑADA · NO EJECUTADA
T-11	R-11	Triage, escalamiento y cierre de alertas	PT-07	DISEÑADA · NO EJECUTADA
T-12	R-12	Autorización y clasificación de transferencias	PT-04	DISEÑADA · NO EJECUTADA
T-13	R-13	Integridad y conciliación CRM–ERP	PT-05	DISEÑADA · NO EJECUTADA
T-14	R-14	Evaluación de chatbot, exactitud y revisión humana	PT-10	DISEÑADA · NO EJECUTADA
T-15	R-15	Indicadores y supervisión del comité	—	DISEÑADA · NO EJECUTADA

14. Fuentes documentales y anexos

Fuentes principales del expediente revisado:

- Proyecto Operación Trazabilidad – Auditoría de Sistemas (enunciado del caso académico).
- Guía Entregables Operación Trazabilidad.

- 01_Plan_Auditoria.docx y Fase1_Organizacion_Equipo_y_Expediente.docx.
- Arquitectura_Logica_Con_Notas.pdf y Flujo_Comercial_Con_Notas.pdf.
- Matriz_Riesgos.xlsx y Matrices_Operacion_Trazabilidad.xlsx.
- ACTUALIZADO_Papeles_Trabajo_PT01_PT10.xlsx e Inventario_Cadena_Custodia_E01_E10.xlsx.
- RedNova.sql, Diccionario_Datos.pdf, INFORME_VERIFICACION.pdf y Evidencias_SQLServer.pdf.
- Informe_Operacion_Trazabilidad.docx, Hallazgos_Operacion_Trazabilidad.docx y Mapa_Causal_Paso8.png.
- ACTUALIZADO_Paso9_TPRM_Privacidad_IA.xlsx y ACTUALIZADO_Matriz_Referencias_Normativas_Paso9.xlsx.
- Plan_Accion.xlsx, ACTUALIZADO_Control_Calidad_Compilacion_Operacion_Trazabilidad.xlsx y ACTUALIZADO_Registro_Uso_IA_Operacion_Trazabilidad.xlsx.
- Declaraciones individuales de uso de IA de Marlon y Oscar, y resumen de uso declarado por Diego.

Referencia técnica utilizada como guía, no como obligación legal asumida: NIST SP 800-53 Rev. 5. La aplicabilidad de cualquier norma o requisito debe comprobarse según el alcance real y los criterios aprobados; el caso es ficticio.

Anexos que acompañan este informe

- Anexo A: Matriz de riesgos R-01 a R-15, Top 5, trazabilidad preliminar y programa T-01 a T-15.
- Anexo B: Papeles de trabajo PT-01 a PT-10 e inventario/cadena de custodia E-01 a E-10.
- Anexo C: Diagrama ER del laboratorio, diccionario y resultados de las 12 consultas SQL sintéticas.
- Anexo D: Hallazgos H-01 a H-05 y hoja de validación cruzada pendiente.
- Anexo E: Evaluación TPRM, privacidad, riesgos IA y matriz de referencias normativas del Paso 9.
- Anexo F: Plan de acción, presupuesto, KPI y control de calidad/compilación.
- Anexo G: Registro de uso de IA.

Enlace Presentación

- Presentación de defensa del equipo: https://flores-oz.github.io/SitioAuditoria/#defensa